Security Monitoring System (AWS)

COMPLETE FORENSIC REPORT

1. Executive Summary

This project built a real-time security monitoring and automated response system on AWS. A honeytoken secret (Production_Database_Credentials) was monitored using two detection flows. Both flows successfully triggered email alerts, and a Lambda kill-switch automatically stripped all permissions from the user who accessed the secret. The entire simulation in region eu-west-2 was 100% successful.

2. Lab Architecture

The solution uses the following AWS services:

- AWS CloudTrail (multi-region trail with CloudWatch Logs integration)
- AWS Secrets Manager (honeytoken secret: Production_Database_Credentials)
- Amazon CloudWatch (Metric Filter + Alarm for Flow 1)
- Amazon EventBridge (rule with wildcard pattern and ENABLED_WITH_ALL_CLOUDTRAIL_MANAGEMENT_EVENTS state for Flow 2)
- Amazon SNS (two topics for email notifications)
- AWS Lambda (RevokeAccessOnSecretAccess function as automated kill-switch)

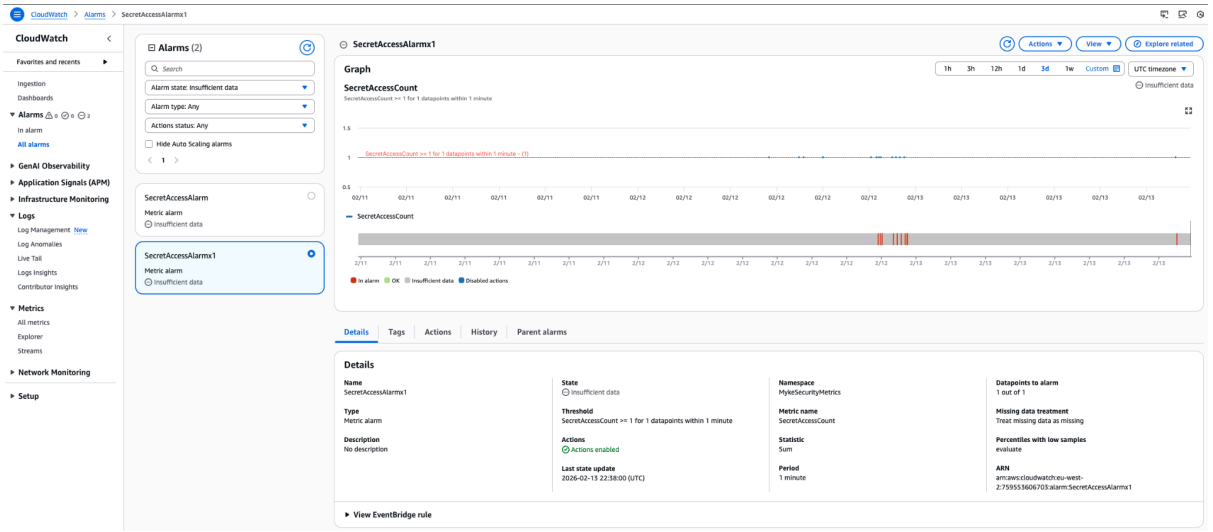


Fig. 1 CloudWatch Alarm configuration (SecretAccessAlarmx1)

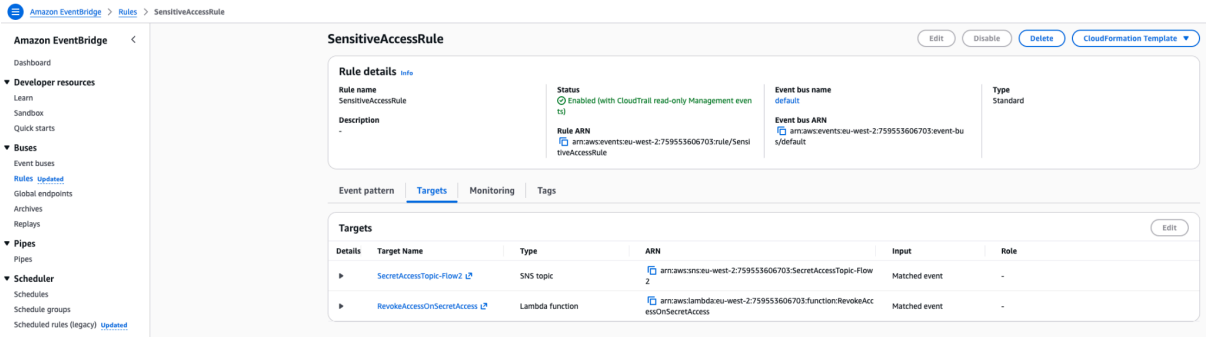


Fig. 2 EventBridge rule (SensitiveAccessRule) showing **two targets** (SNS topic SecretAccessTopic-Flow2" + Lambda function "RevokeAccessOnSecretAccess")

3. The Evidence (Logs)

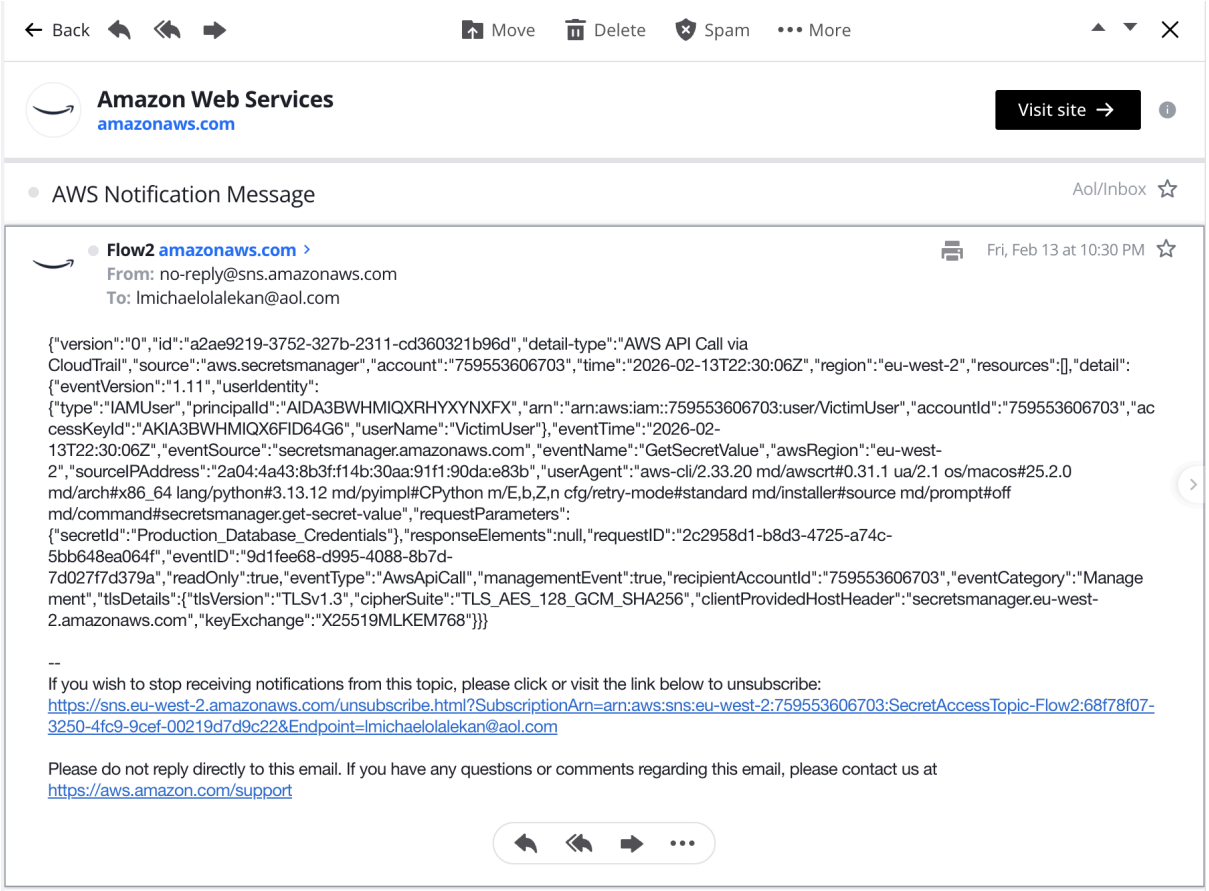
CloudTrail JSON snippet from the secret access event:

```JSON
{
    "eventVersion": "1.11",
    "userIdentity": {
        "type": "IAMUser",
        "principalId": "AIDA3BWHMIQXRHYXYNXFX",
        "arn": "arn:aws:iam::759553606703:user/VictimUser",
        "accountId": "759553606703",
        "accessKeyId": "AKIA3BWHMIQX6FID64G6",
        "userName": "VictimUser"
    },
    "eventTime": "2026-02-13T22:30:06Z",
    "eventSource": "secretsmanager.amazonaws.com",
    "eventName": "GetSecretValue",
    "awsRegion": "eu-west-2",
    "sourceIPAddress": "2a04:4a43:8b3f:f14b:30aa:91f1:90da:e83b",
    "userAgent": "aws-cli/2.33.20 md/awscrt#0.31.1 ua/2.1 os/macos#25.2.0
md/arch#x86_64 lang/python#3.13.12 md/pyimpl#CPython m/E,b,Z,n
cfg/retry-mode#standard md/installer#source md/prompt#off
md/command#secretsmanager.get-secret-value",
    "requestParameters": {
        "secretId": "Production_Database_Credentials"
    },
    "responseElements": null,
    "requestID": "2c2958d1-b8d3-4725-a74c-5bb648ea064f",
```

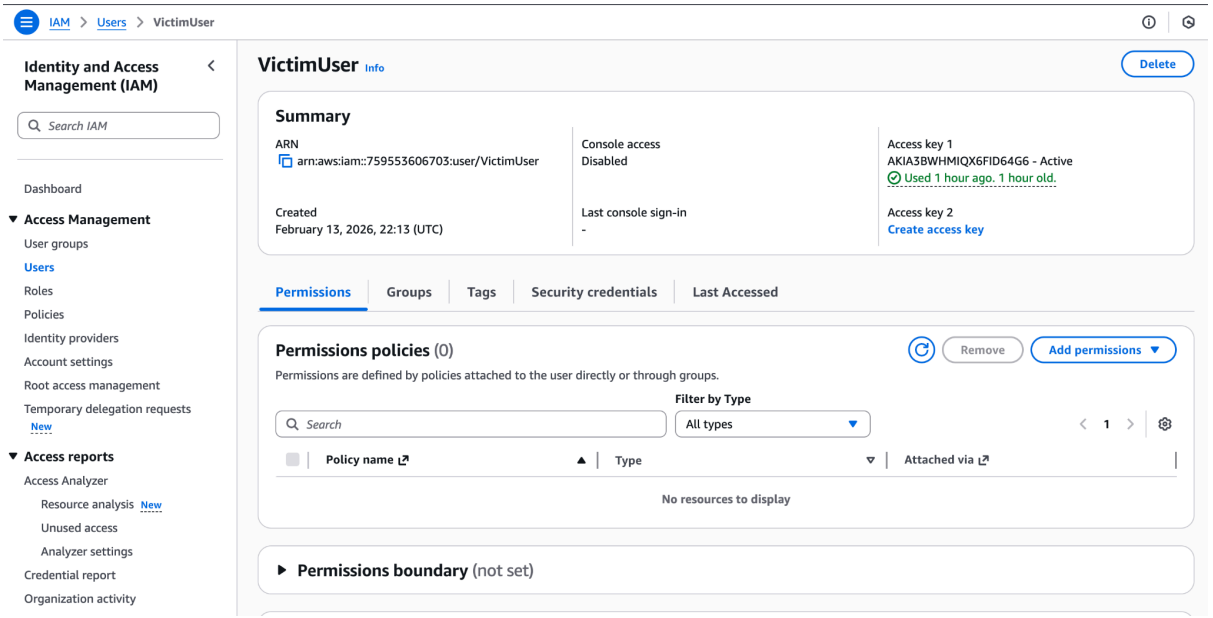
```
    "eventID": "9d1fee68-d995-4088-8b7d-7d027f7d379a",
    "readOnly": true,
    "eventType": "AwsApiCall",
    "managementEvent": true,
    "recipientAccountId": "759553606703",
    "eventCategory": "Management",
    "tlsDetails": {
        "tlsVersion": "TLSv1.3",
        "cipherSuite": "TLS_AES_128_GCM_SHA256",
        "clientProvidedHostHeader": "secretsmanager.eu-west-2.amazonaws.com",
        "keyExchange": "X25519MLKEM768"
    }
}
```


4. Technical Evidence (Screenshots Required)

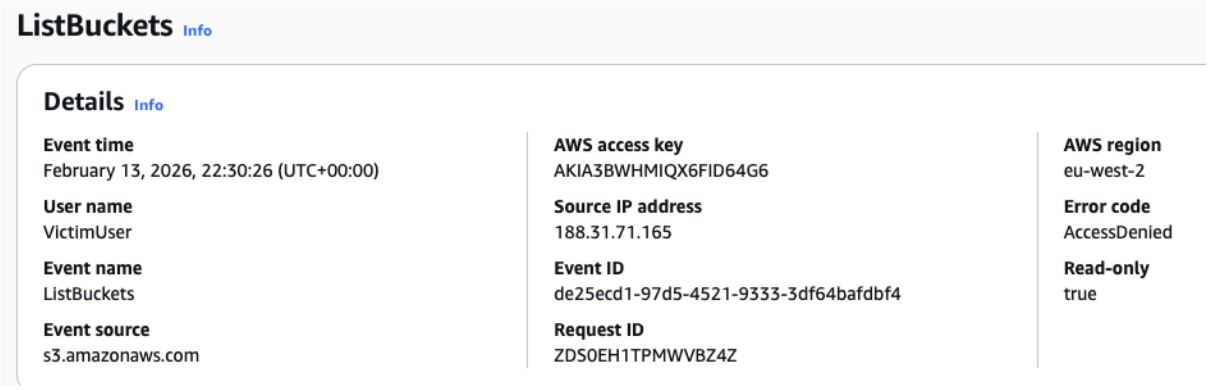
- Email notification from Flow 2 (EventBridge)



- IAM console for VictimUser showing **zero attached policies**

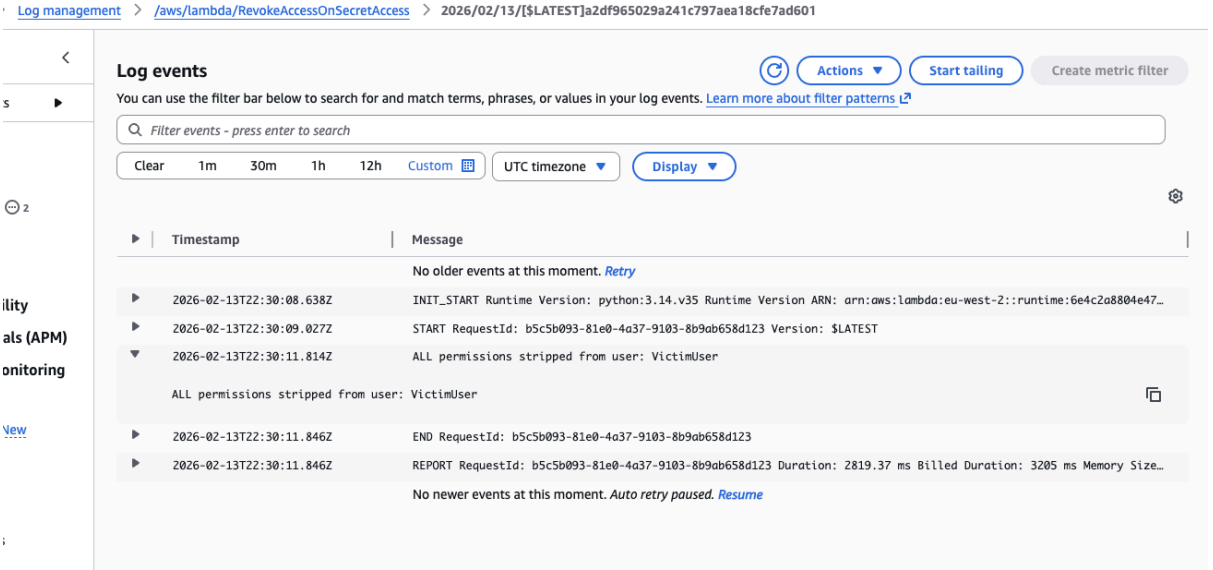


- CloudTrail log of the second CLI command showing errorCode: "AccessDenied"




```
5         "principalId": "AIDA3BWHMIQXRHYXYNXFX",
6         "arn": "arn:aws:iam::759553606703:user/VictimUser",
7         "accountId": "759553606703",
8         "accessKeyId": "AKIA3BWHMIQX6FID64G6",
9         "userName": "VictimUser"
10     },
11     "eventTime": "2026-02-13T22:30:26Z",
12     "eventSource": "s3.amazonaws.com",
13     "eventName": "ListBuckets",
14     "awsRegion": "eu-west-2",
15     "sourceIPAddress": "188.31.71.165",
16     "userAgent": "[aws-cli/2.33.20 md/awscrt#0.31.1 ua/2.1 os/macos#25.2.0 md/arch#x86_64 lang/python
17     "errorCode": "AccessDenied",
18     "errorMessage": "User: arn:aws:iam::759553606703:user/VictimUser is not authorized to perform: s3
19     "requestParameters": {
```

- Lambda CloudWatch Logs showing “Permissions stripped from: VictimUser”



5. Security Analysis

- **Speed**: Flow 2 (EventBridge) notified faster (usually < 60 seconds) than Flow 1 (CloudWatch Metric Filter).
- **Context**: Flow 2 provided richer information (exact user name, source IP, full event details). To automatically block the user after the alert, I used **AWS Lambda** triggered by EventBridge.
- **Compliance**: This lab satisfies the **Continuous Monitoring** requirement of NIST SP 800-53 (CM-3 and SI-4) by delivering real-time logging, detection, alerting, **and** automated response.

6. Lessons Learned

For a bank I would prefer **EventBridge (Flow 2)** to trigger the kill-switch. It is near real-time, supplies the Lambda with full event context, and is more reliable than the CloudWatch metric filter. The key technical fixes were the %Production_Database_Credentials% wildcard in the metric filter and using the special state **`ENABLED_WITH_ALL_CLOUDTRAIL_MANAGEMENT_EVENTS`** for the EventBridge rule.